

CSRF where token is duplicated in cookie

Category: Cross-Site Request Forgery (CSRF)

Platform: PortSwigger Web Security Academy

Difficulty: Practitioner

Tool: Burp Suite

Objective

Exploit a CSRF vulnerability where the application stores the CSRF token in both a cookie and a request parameter, allowing the token value to be manipulated.

Vulnerability

The application uses a double-submit style CSRF protection mechanism but does not properly bind the token to the user's session. Because the token value can be influenced through the cookie, an attacker can control the value used during validation.

Methodology

1. Intercepted the vulnerable state-changing request using Burp Suite.
2. Identified that the CSRF token was present in both the cookie and request parameter.
3. Determined that the application accepted an attacker-controlled token when the cookie and parameter contained the same value.
4. Crafted a malicious CSRF request containing the controlled token.
5. Submitted the request and verified that the protected action was successfully performed.

Impact

An attacker can potentially perform unauthorized state-changing actions in the context of a victim's authenticated session.

Remediation

Use cryptographically random, session-bound CSRF tokens. The server should validate that the token is associated with the authenticated user's session rather than relying solely on matching values between a cookie and request parameter.